Capacitación en Concientización de Seguridad — Cliente A

> **Nota sobre anonimización.** Este informe documenta un trabajo real, realizado con autorización del propietario. El nombre del cliente y los identificadores de su infraestructura se reemplazaron por marcadores (`Cliente A` , `cliente-a`) antes de publicarlo. Belona Cybersecurity no publica datos identificables de un cliente sin su autorización por escrito.

Dirigido a: usuarios del panel · Estudio jurídico

Marco de referencia: CIS Controls v8 — **Control 14** (Security Awareness and Skills Training) y **NIST CSF — PR.AT** (Awareness and Training). Cada módulo indica el control que lo respalda.

> Objetivo: que las personas que usan el sistema entiendan los riesgos y actúen de forma segura. **El eslabón más débil suele ser el humano, no la tecnología.**

Módulo 1 — Contraseñas y gestión de credenciales

(CIS 14.x · NIST PR.AT / PR.AC) - Usá contraseñas **largas y únicas** (frase de 12+ caracteres). Nunca reutilices la del correo. - Usá un **gestor de contraseñas** (para no memorizar ni anotar en papel). - **Nunca compartas tu cuenta ni tu contraseña** — cada persona tiene la suya (así los Logs saben quién hizo qué). - Si sospechás que alguien la vio, **cambiala de inmediato**.

Módulo 2 — Autenticación en dos pasos (MFA)

(NIST PR.AC-7) - El panel exige **MFA (Google Authenticator)** — es tu segunda barrera si roban tu contraseña. - **No aceptes** solicitudes de MFA que no iniciaste vos (podría ser un atacante intentando entrar). - Guardá bien el acceso a tu app de Authenticator.

Módulo 3 — Phishing e ingeniería social

(CIS 14.2 · los estudios jurídicos son blanco frecuente) - **Desconfiá de correos/mensajes urgentes** que piden credenciales, clics o transferencias. - Verificá el **remitente real** y **no hagas clic** en links sospechosos (pasá el mouse para ver la URL real). - Ante un "correo del banco/Google/jefe" pidiendo datos → **confirmá por otro canal** antes de actuar. - Recordá: nadie legítimo te va a pedir tu contraseña por correo.

Módulo 4 — Manejo de datos confidenciales de clientes (Ley 1581)

(CIS 14.4 · cumplimiento legal) - Los datos de consultas y expedientes son **confidenciales y sensibles**. Tratalos con el máximo cuidado. - **No descargues** documentos de clientes a dispositivos personales sin necesidad; no los reenvíes por canales inseguros. - Accedé solo a lo que necesitás para tu trabajo (**mínimo privilegio**). - Ante un pedido de un cliente sobre sus datos (acceso, corrección, supresión) → seguir el procedimiento de la Política de Tratamiento.

Módulo 5 — Uso seguro del panel de administración

(NIST PR.AC) - **Cerrá sesión** cuando termines, sobre todo en equipos compartidos. - **Bloqueá la pantalla** (Win+L) si te alejás del equipo. - No dejes el panel abierto a la vista de terceros. - Usá tu rol asignado; si necesitás más permisos, pedilos (no busques rodeos).

Módulo 6 — Dispositivos y redes

(CIS 14.x) - Mantené el sistema operativo y el navegador **actualizados**. - Tené **antivirus** activo. - Cuidado con **WiFi público**: evitá acceder al panel desde redes no confiables. - No instales extensiones/programas de origen dudoso.

Módulo 7 — Reporte de incidentes

(CIS 14.6 · NIST RS) - Si ves **algo raro** (un correo sospechoso, una alerta, acceso que no reconocés, un archivo cambiado): 1. **No lo ignores.** 2. **Avisá de inmediato** al responsable técnico y/o a legal@cliente-a.example. 3. No intentes "arreglarlo" solo si no estás seguro. - Reportar a tiempo puede evitar un incidente grave. **Reportar no es molestar, es proteger.**

Evaluación rápida (marcá lo que harías bien)

- [ ] Uso una contraseña única y MFA
- [ ] No comparto mi cuenta
- [ ] Verifico remitentes antes de hacer clic
- [ ] Cierro sesión y bloqueo la pantalla
- [ ] Sé a quién avisar ante un incidente

Frecuencia recomendada

- Capacitación **al ingresar** + **repaso anual** (CIS 14.1).

- Actualizar el material cuando cambien las amenazas o el sistema.

Basado en CIS Controls v8 (Control 14) y NIST CSF (PR.AT). Ver también los playbooks de respuesta a incidentes.